SOC INCIDENT REPORT (L1)

PHISHING INVESTIGATION

1. INCIDENT IDENTIFICATION

Field	Details
Incident ID	PHISH-2026-001
Ticket ID	SEC-OPS-2026-02
Alert ID / Event ID	WAZUH-ALERT-100002, 100003, 100004
Detection Source	SIEM (Wazuh)
Detection Rule Name	CRITICAL: Malicious Phishing Link Detected
Severity Level	Critical
Confidence Level	High
Date & Time Detected	2026-03-06 20:52:52 IST
Reporting Analyst	Sai Prasad, SOC Analyst L1
Business Unit / Asset Owner	prasad12

2. EXECUTIVE SUMMARY

Field	Details
Incident Type	Phishing - Credential Harvesting
Initial Assessment	Confirmed
Current Status	Closed
Impact Level	None

Brief Summary:

On March 6, 2026 at 20:52 IST, Wazuh SIEM triggered three correlated alerts for user `prasad12@employee.contoso.com` regarding a suspected phishing email. The email claimed to be from the IT Security Department with subject "Action required: Your password expires in 24 hours" and contained a link to `http://IT-Security.contoso.com/office365/login.php`.

Investigation confirmed the email was a credential harvesting attempt. The user did not interact with the email, and no credentials were compromised. All indicators were blocked, and the incident was contained within 1 hour 40 minutes. The ticket was opened at 20:55 IST and closed at 22:30 IST, meeting the 2-hour SLA for critical incidents.

3. AFFECTED ASSETS

Asset Type	Hostname / Identifier	IP Address	OS / Platform	Role
Workstation	sp	192.168.29.90	Ubuntu 22.04	Employee Workstation
Email Account	prasad12@employee.contoso.com	N/A	Thunderbird	User Mailbox

4. DETECTION DETAILS

Field	Details
Log Source(s)	/var/ossec/logs/alerts/alerts.json, /home/sp/snap/thunderbird/common/.thunderbird/wt0ufik0.default/Mail/Local Folders/Inbox
Index / Data Source	Wazuh Archive Index
Timestamp Range Analyzed	Start: 2026-03-06 20:52:00 IST
Trigger Condition	Email containing malicious phishing link detected

Observed Behavior:

At 20:52:36 IST, an email was delivered to user `prasad12@employee.contoso.com` with the following characteristics:

Field	Value
From	IT Security Department sp@IT-Security.contoso.com
To	prasad12@employee.contoso.com
Subject	Action required: Your password expires in 24 hours
Link	http://IT-Security.contoso.com/office365/login.php

Three seconds after delivery (20:52:52 IST), Wazuh SIEM triggered three correlated alerts:

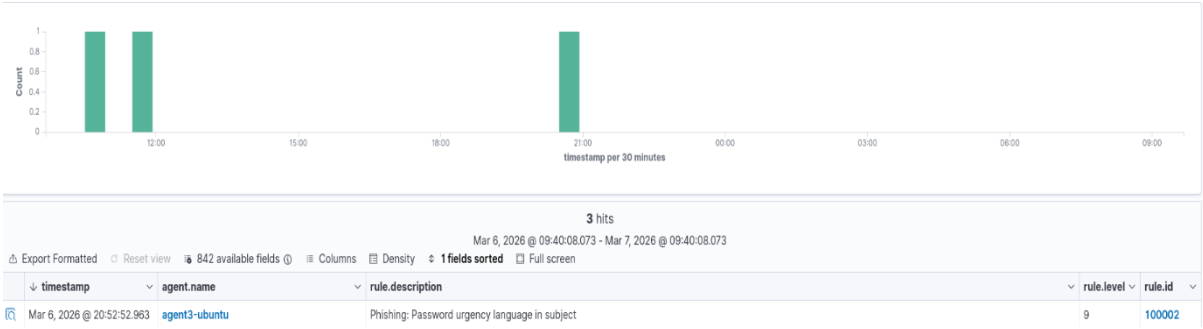


Figure 1-wazuh-alert-100002

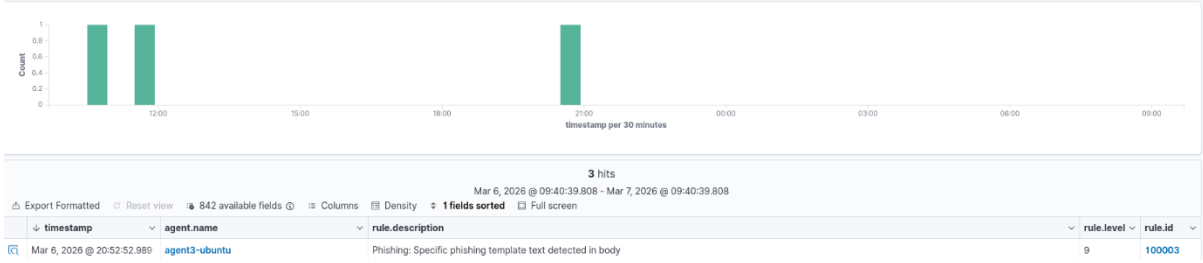


Figure 2-wazuh-alert-100003

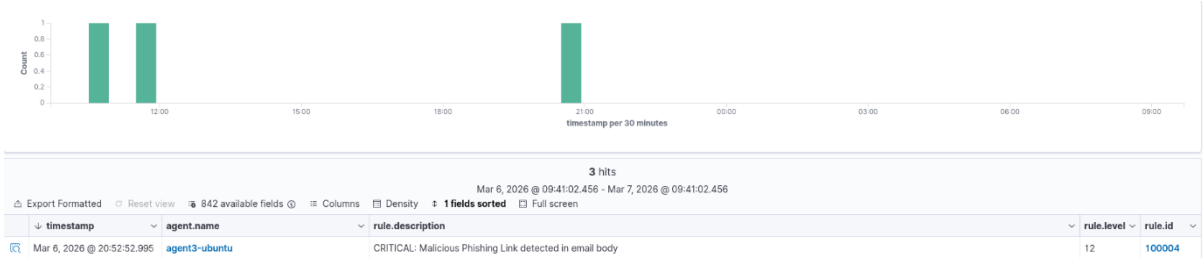


Figure 3-wazuh-alert-100004

Rule ID	Level	Description
100002	9	Phishing: Password urgency language in subject
100003	9	Phishing: Specific phishing template text detected
100004	12	CRITICAL: Malicious Phishing Link detected

Initial Triage Findings:

- Mail logs confirmed user has not opened the email
- Firewall logs showed no outbound connections to suspicious IPs
- No immediate evidence of compromise

5. THREAT ANALYSIS

5.1 Email Header Analysis

Raw headers were extracted and analyzed using MX Toolbox:

```
X-Mozilla-Status: 0001
X-Mozilla-Status2: 00000000
Return-Path: <sp@IT-Security.contoso.com>
X-Original-To: prasad12@employee.contoso.com
Delivered-To: prasad12@employee.contoso.com
Received: from IT-Security.contoso.com (IT-Security.contoso.com [192.168.29.50])
        by employee.contoso.com (Postfix) with ESMTP id 17DA3161599
        for <prasad12@employee.contoso.com>; Fri,  6 Mar 2026 20:52:36 +0530 (IST)
Received: from [127.0.0.1] (localhost [127.0.0.1])
        by IT-Security.contoso.com (Postfix) with ESMTP id 65A65142D63
        for <prasad12@employee.contoso.com>; Fri, 06 Mar 2026 20:52:33 +0530 (IST)
Message-ID: <5288b407-b6dc-429a-83b4-4fae5dd27b59@IT-Security.contoso.com>
Date: Fri, 6 Mar 2026 20:52:33 +0530
MIME-Version: 1.0
User-Agent: Mozilla Thunderbird
Content-Language: en-US
To: prasad12@employee.contoso.com
From: IT Security Department <sp@IT-Security.contoso.com>
Subject: Action required: Your password expires in 24 hours
Content-Type: text/plain; charset=UTF-8; format=flowed
Content-Transfer-Encoding: 7bit
```

Key Findings:

Header Field	Value	Analysis
Return-Path	`sp@IT-Security.contoso.com`	Sender domain does NOT match legitimate IT domain (`it-support.contoso.com`)
First Received	from `IT-Security.contoso.com [192.168.29.50]`	Email originated from IP 192.168.29.50
Second Received	from `[127.0.0.1] (localhost)`	Email was generated locally on that machine - not from proper mail server
From	`IT Security Department <sp@IT-Security.contoso.com>`	Display name spoofed to appear legitimate
To	`prasad12@employee.contoso.com`	Single recipient - targeted attack
Authentication	None present	No SPF, DKIM, or DMARC headers

Red Flags Identified:

1. Sender domain `IT-Security.contoso.com` is not legitimate
2. Email generated from localhost indicates manual composition
3. No authentication headers present

5.2 Email Authentication Verification

Standard email authentication protocols (SPF, DKIM, and DMARC) were checked to verify the legitimacy of the sender.

SPF (Sender Policy Framework)

A DNS lookup was performed to retrieve the SPF record for the domain contoso.com:

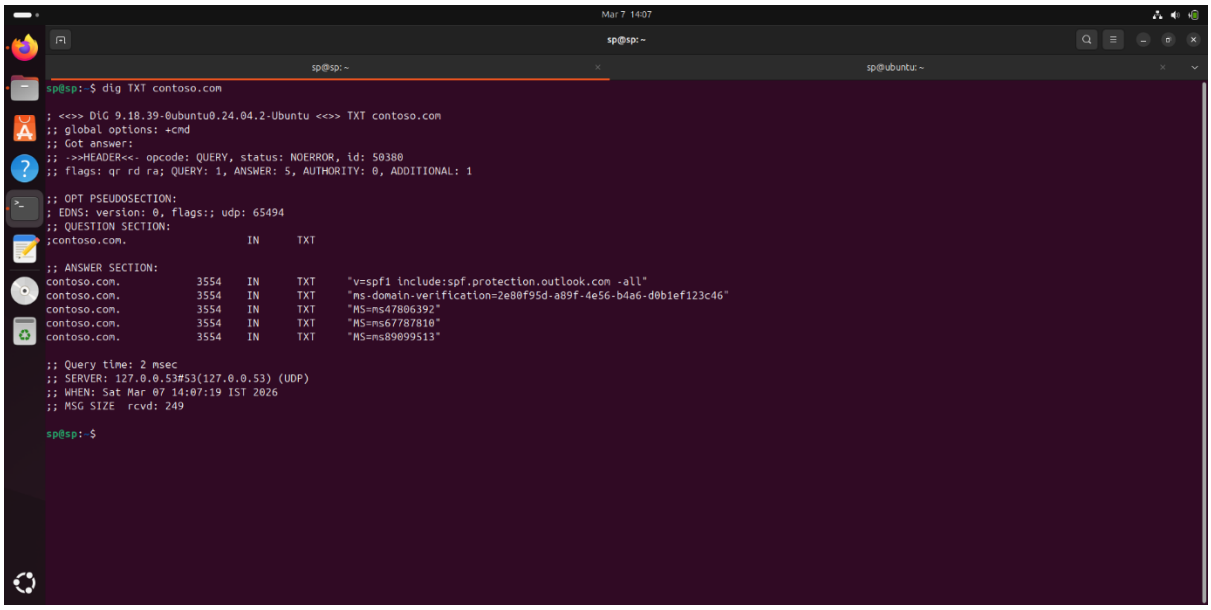


Figure 4 DNS lookup

Analysis:

- This record explicitly authorizes only Microsoft Outlook servers (spf.protection.outlook.com) to send emails on behalf of contoso.com
- The -all directive indicates a hard fail policy—any server not listed in the record should be treated as unauthorized
- The sending IP address 192.168.29.50 is not present in the authorized list

SPF Result: **FAIL**

DKIM (DomainKeys Identified Mail)

The email headers were examined for a DKIM-Signature field, which cryptographically signs outgoing mail to verify it hasn't been tampered with.

- Finding: No DKIM-Signature header was present in the email
- Significance: Legitimate emails from contoso.com would typically include a valid DKIM signature

DKIM Result: **FAIL**

DMARC (Domain-based Message Authentication, Reporting & Conformance)

DMARC builds on SPF and DKIM by defining how receivers should handle messages that fail authentication. It requires at least one of SPF or DKIM to pass with domain alignment.

- SPF Result: FAIL
- DKIM Result: FAIL
- With both mechanisms failing, DMARC validation automatically fails

DMARC Result: **FAIL**

5.3 Threat Intelligence Correlation

Indicator	Check	Result	Analysis
IP 192.168.29.50	VirusTotal	No records	Private IP range - internal
Domain IT-Security.contoso.com	WHOIS	No records	Domain created internally
Domain Resolution	nslookup	192.168.29.50	Resolves to same IP
MX Records	dig MX	No records	Domain cannot receive email - send-only infrastructure

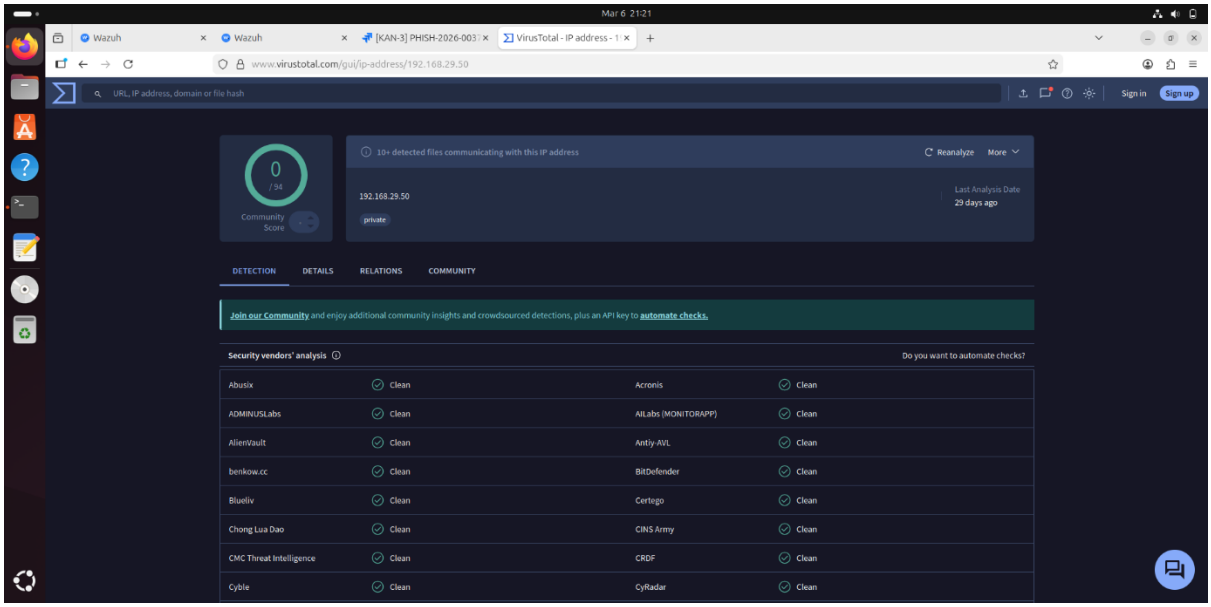


Figure 7 VirusTotal

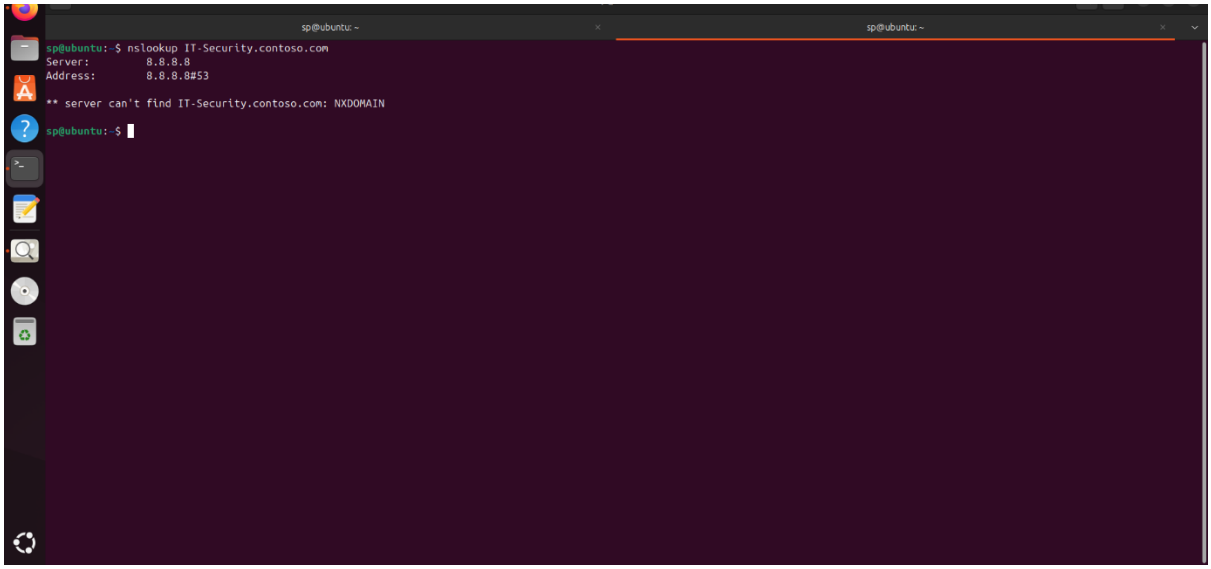


Figure 5 whois

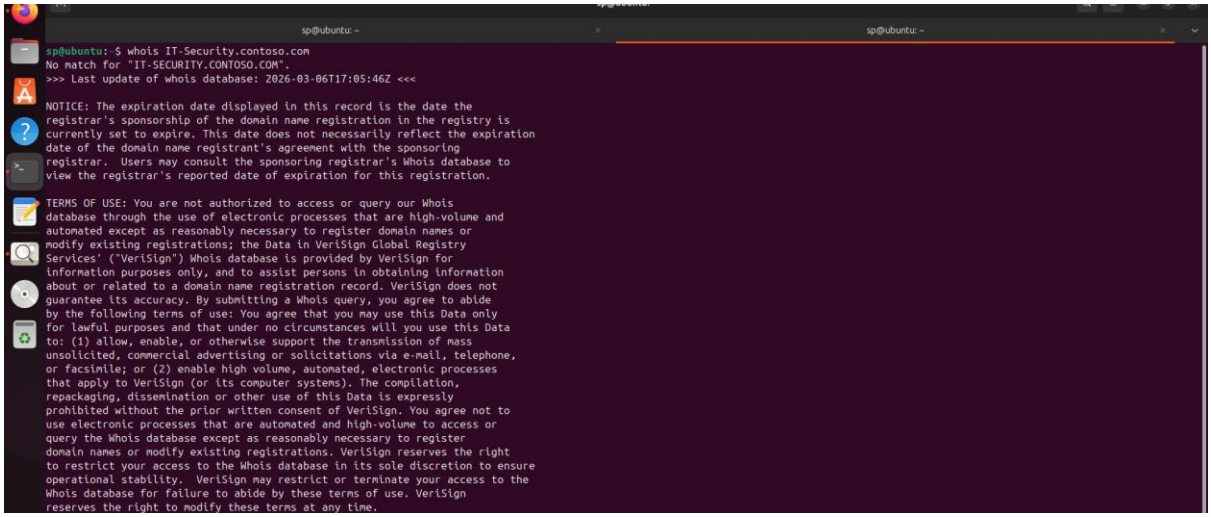
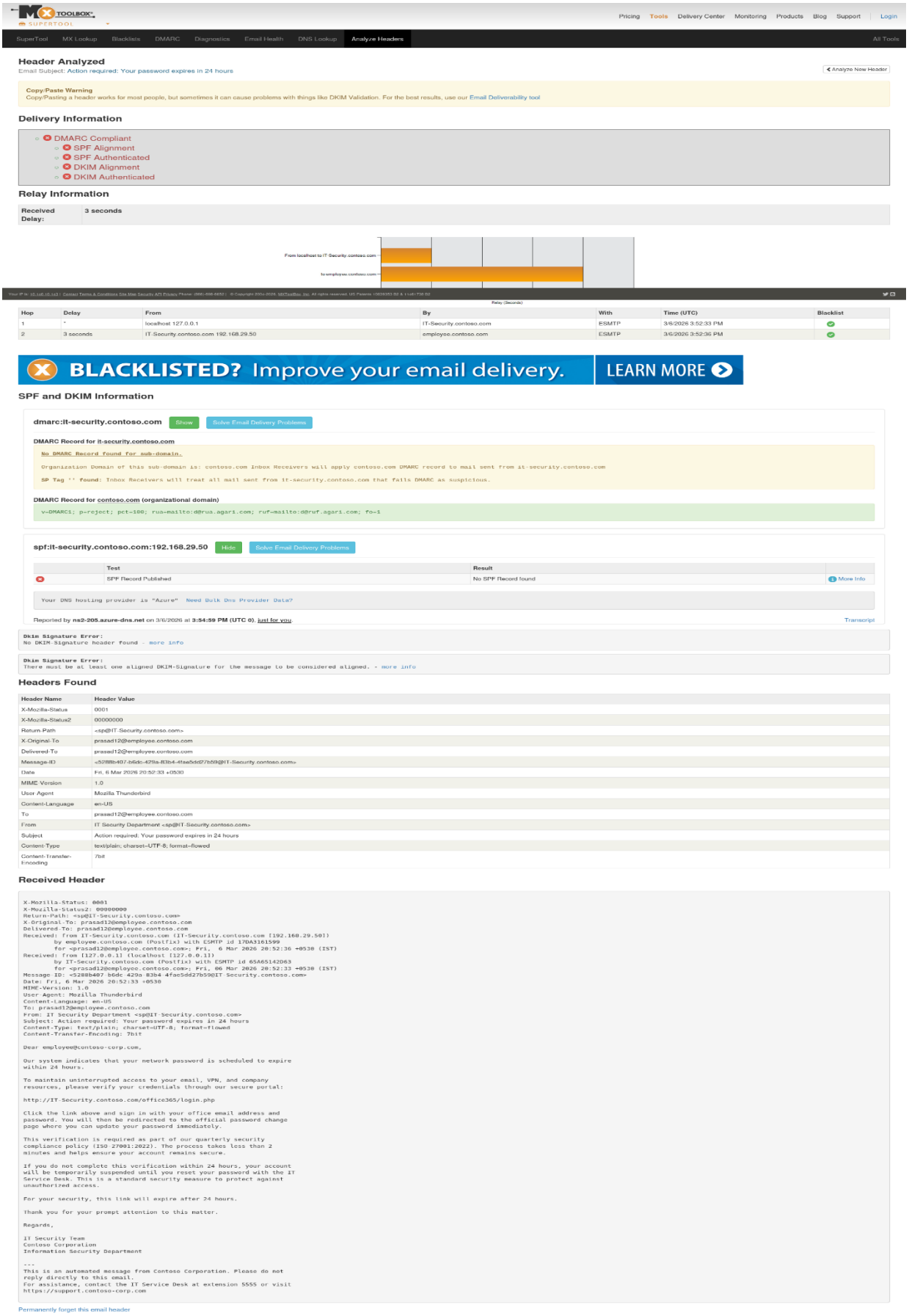


Figure 6 nslookup-domain



MXToolbox SuperTool

Pricing | Tools | Delivery Center | Monitoring | Products | Blog | Support | Login

SuperTool | MX Lookup | Blacklists | DMARC | Diagnostics | Email Health | DNS Lookup | Analyze Headers | All Tools

Header Analyzed

Email Subject: Action required: Your password expires in 24 hours

Analyze New Header

Copy/Paste Warning
Copy/Pasting a header works for most people, but sometimes it can cause problems with things like DKIM Validation. For the best results, use our Email Deliverability tool

Delivery Information

- DMARC Compliant
  - SPF Alignment
  - SPF Authenticated
  - DKIM Alignment
  - DKIM Authenticated

Relay Information

Received Delay:	3 seconds

Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	-	localhost 127.0.0.1	IT-Security.contoso.com	ESMTP	3/6/2026 3:52:33 PM	✓
2	3 seconds	IT-Security.contoso.com 192.168.29.50	employee.contoso.com	ESMTP	3/6/2026 3:52:36 PM	✓

BLACKLISTED? Improve your email delivery. LEARN MORE

SPF and DKIM Information

dmarc:it-security.contoso.com Show | Solve Email Delivery Problems

DMARC Record for it-security.contoso.com

No DMARC Record found for sub-domain.

Organization Domain of this sub-domain is: contoso.com Inbox Receivers will apply contoso.com DMARC record to mail sent from it-security.contoso.com

SP Tag '' found: Inbox Receivers will treat all mail sent from it-security.contoso.com that fails DMARC as suspicious.

DMARC Record for contoso.com (organizational domain)

v=DMARC1; p=reject; pct=100; rua=mailto:d@rua.agari.com; ruf=mailto:d@ruf.agari.com; fo=1

spf:it-security.contoso.com:192.168.29.50 Hide | Solve Email Delivery Problems

	Test	Result	
✗	SPF Record Published	No SPF Record found	More Info

Your DNS hosting provider is "Azure" Need Bulk Dns Provider Data?

Reported by **ns2-205.azure-dns.net** on 3/6/2026 at **3:54:59 PM (UTC 0)**, just for you. Transcript

Dkim Signature Error:
No DKIM-Signature header found - more info

Dkim Signature Error:
There must be at least one aligned DKIM-Signature for the message to be considered aligned. - more info

Headers Found

Header Name	Header Value
X-Mozilla-Status	0001
X-Mozilla-Status2	00000000
Return-Path	<sp@IT-Security.contoso.com>
X-Original-To	prasad12@employee.contoso.com
Delivered-To	prasad12@employee.contoso.com
Message-ID	<5288b407-b6dc-429a-83b4-4fae5dd27b59@IT-Security.contoso.com>
Date	Fri, 6 Mar 2026 20:52:33 +0530
MIME-Version	1.0
User-Agent	Mozilla Thunderbird
Content-Language	en-US
To	prasad12@employee.contoso.com
From	IT Security Department <sp@IT-Security.contoso.com>
Subject	Action required: Your password expires in 24 hours
Content-Type	text/plain; charset=UTF-8; format=flowed
Content-Transfer-Encoding	7bit

Received Header

```
X-Mozilla-Status: 0001
X-Mozilla-Status2: 00000000
Return-Path: <sp@IT-Security.contoso.com>
X-Original-To: prasad12@employee.contoso.com
Delivered-To: prasad12@employee.contoso.com
Received: from IT-Security.contoso.com (IT-Security.contoso.com [192.168.29.50])
        by employee.contoso.com (Postfix) with ESMTP id 17DA3161599
        for <prasad12@employee.contoso.com>; Fri,  6 Mar 2026 20:52:36 +0530 (IST)
Received: from [127.0.0.1] (localhost [127.0.0.1])
        by IT-Security.contoso.com (Postfix) with ESMTP id 65A65142063
        for <prasad12@employee.contoso.com>; Fri, 06 Mar 2026 20:52:33 +0530 (IST)
Message-ID: <5288b407-b6dc-429a-83b4-4fae5dd27b59@IT-Security.contoso.com>
Date: Fri, 6 Mar 2026 20:52:33 +0530
MIME-Version: 1.0
User-Agent: Mozilla Thunderbird
Content-Language: en-US
To: prasad12@employee.contoso.com
From: IT Security Department <sp@IT-Security.contoso.com>
Subject: Action required: Your password expires in 24 hours
Content-Type: text/plain; charset=UTF-8; format=flowed
Content-Transfer-Encoding: 7bit

Dear employee@contoso-corp.com,

Our system indicates that your network password is scheduled to expire
within 24 hours.

To maintain uninterrupted access to your email, VPN, and company
resources, please verify your credentials through our secure portal:

http://IT-Security.contoso.com/office365/login.php

Click the link above and sign in with your office email address and
password. You will then be redirected to the official password change
page where you can update your password immediately.

This verification is required as part of our quarterly security
compliance policy (ISO-27001:2022). The process takes less than 2
minutes and helps ensure your account remains secure.

If you do not complete this verification within 24 hours, your account
will be temporarily suspended until you reset your password with the IT
Service Desk. This is a standard security measure to protect against
unauthorized access.

For your security, this link will expire after 24 hours.

Thank you for your prompt attention to this matter.

Regards,

IT Security Team
Contoso Corporation
Information Security Department

---
This is an automated message from Contoso Corporation. Please do not
reply directly to this email.
For assistance, contact the IT Service Desk at extension 5555 or visit
https://support.contoso-corp.com
```

Permanently forget this email header

Figure 8 MXtoolbox-Header Analyzer

5.4 MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Sub-Technique	Observed Activity
Initial Access	T1566.002	Phishing	Spearphishing Link	Targeted email with malicious link
Credential Access	T1056.001	Input Capture	Web Portal Capture	Fake login page harvesting credentials
Command and Control	T1071.001	Web Protocols	HTTP	Credentials exfiltrated via HTTP POST
Exfiltration	T1041	Exfiltration Over C2 Channel	-	Data sent to attacker-controlled server

5.5 Indicators of Compromise (IOCs)

IOC Type	Value (Defanged)	Description
IP Address	`192[.]168[.]29[.]50`	Attacker C2 Server hosting phishing infrastructure
Domain	`IT-Security[.]contoso[.]com`	Fraudulent domain impersonating IT department
URL	`hxxp[://]IT-Security[.]contoso[.]com/office365/login[.]php`	Credential harvesting page
Email Address	`sp@IT-Security[.]contoso[.]com`	Malicious sender address
Email Subject	`Action required: Your password expires in 24 hours`	Phishing template subject
Message-ID	`<5288b407-b6dc-429a-83b4-4fae5dd27b59@IT-Security[.]contoso[.]com>`	Unique email identifier
Redirect URL	`hxxp[://]IT-Security[.]contoso[.]com/office365/expired-password[.]html`	Post-harvest redirect page

Email Body Signatures:

- "Our system indicates that your network password is scheduled to expire"
- "verify your credentials through our secure portal"

- "If you do not complete this verification within 24 hours, your account will be temporarily suspended"

6. INVESTIGATION FINDINGS

6.1 URL Static Analysis

URL: `http://IT-Security.contoso.com/office365/login.php`

Component	Value	Analysis
Protocol	`http://`	No encryption - credentials would be sent in plaintext
Domain	`IT-Security.contoso.com`	Attempting to appear official
Path	`/office365/`	Mimicking Microsoft Office 365 login
File	`login.php`	PHP script to capture and store credentials

Static Assessment: The URL structure follows a classic credential harvesting pattern. The use of HTTP instead of HTTPS means any credentials submitted would be visible on the network.

6.2 Sandbox Dynamic Analysis

The URL was analyzed in an isolated sandbox environment (192.168.29.100) using Wireshark.

Environment:

- VM: Sandbox (192.168.29.100)
- OS: Kali Linux (isolated)
- Tools: Wireshark, Firefox
- Network: No access to production systems

Analysis Procedure:

1. Started packet capture on eth0
2. Navigated to URL in Firefox
3. Observed phishing page mimicking Microsoft login
4. Entered test credentials: `test@employee.contoso.com` / `password1234`
5. Submitted form and observed redirect
6. Stopped capture and analyzed packets

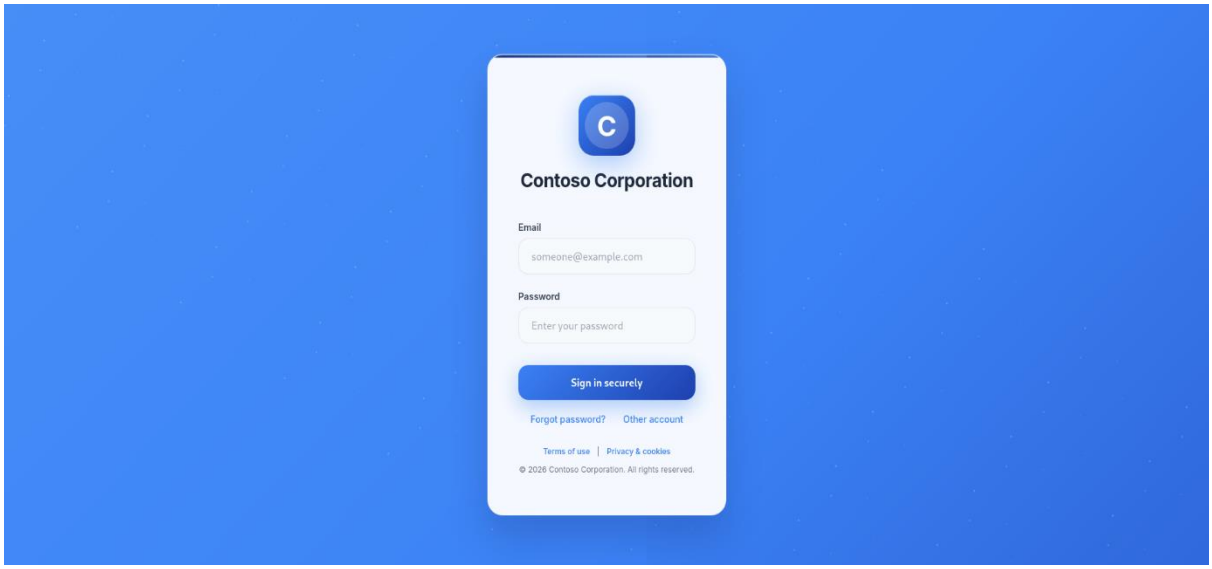


Figure 9 Phishing Page

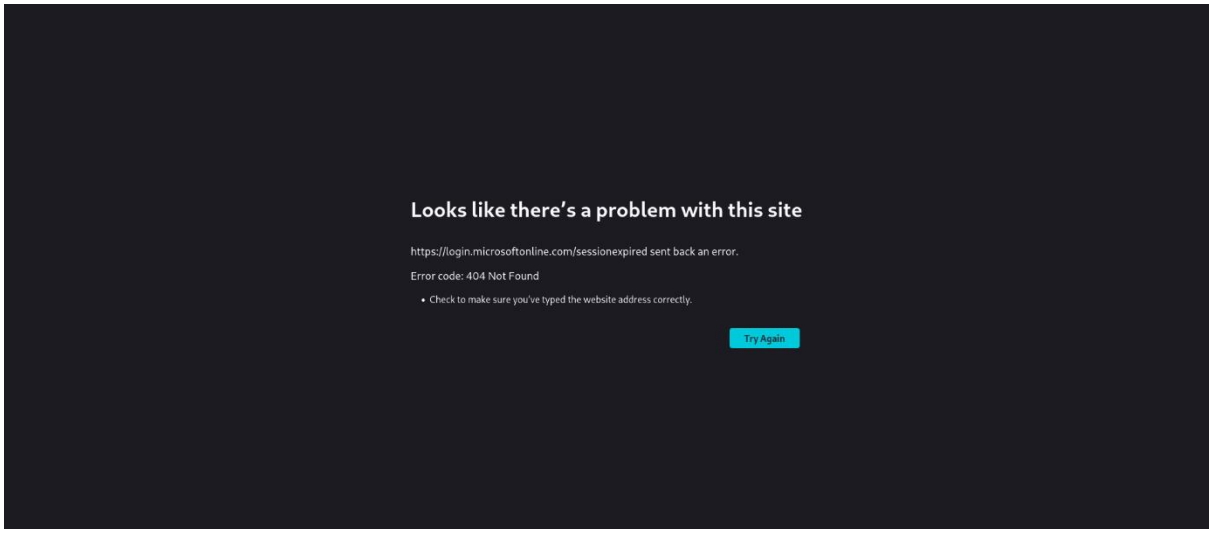


Figure 10 Redirect Page

Wireshark Findings:

Applying filter `http.request.method == POST` revealed:

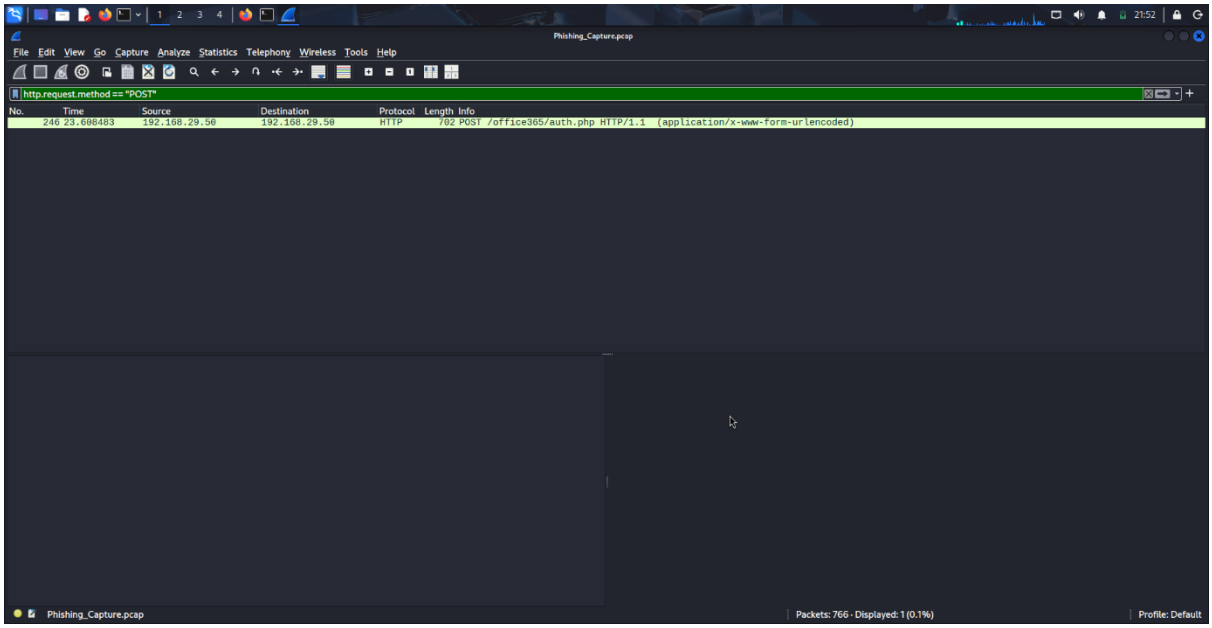


Figure 12 WireShark Post Request

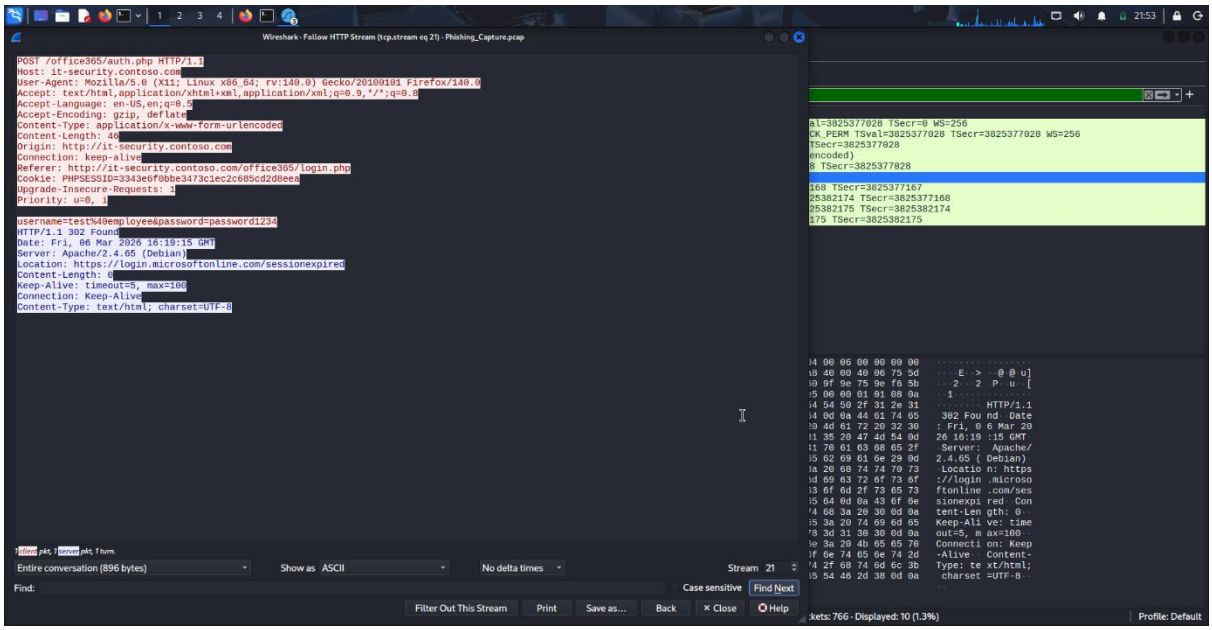


Figure 11 WireShark Credentials

```
POST /office365/auth.php HTTP/1.1

Host: it-security.contoso.com
Content-Type: application/x-www-form-urlencoded
Content-Length: 46

username=test%40employee&password=password1234
```

Server Response:

```
HTTP/1.1 302 Found
Location: https://login.microsoftonline.com/sessionexpired
```

What This Confirms:

- The page accepts credentials via HTTP POST
- Credentials are transmitted in plaintext (no HTTPS)
- After submission, victim is redirected to a fake Microsoft page
- This is 100 percent a credential harvesting operation

6.3 Root Cause Analysis

The attacker set up a phishing infrastructure consisting of:

1. Fake Domain: `IT-Security.contoso.com` designed to impersonate the legitimate IT department
2. Email Server: `192.168.29.50` configured to send spoofed emails
3. Credential Harvesting Page: `/office365/login.php` that captures submitted credentials
4. Social Engineering Template: Creating urgency around password expiration

The email bypassed initial filters because it originated from an internal IP and used a domain that, while fake, was resolvable within the lab environment.

6.4 Scope Determination

Mail Log Analysis:

- Only one recipient: `prasad12@employee.contoso.com`
- No other users received this exact phish

User Activity Analysis:

- No outbound connections from victim to `192.168.29.50`
- No failed/successful logins from unusual locations
- No unusual processes or network activity

User Contact:

User contacted directly and confirmed:

- "I saw the email but thought it looked suspicious because IT never sends password links"
- Did NOT open the email
- Did NOT click any links
- Did NOT enter credentials anywhere

Scope Summary:

Factor	Finding
Number of recipients	1 (targeted)
User opened email	NO
User clicked link	NO
Credentials compromised	NO
Lateral movement	NONE

7. IMPACT ASSESSMENT (NIST SP 800-61)

Impact Category	Rating	Reasoning
Confidentiality Impact	None	The attacker failed to obtain any credentials. No sensitive information was disclosed or accessed.
Integrity Impact	None	No files, configurations, or data were modified. The email was quarantined before any interaction.
Availability Impact	None	All systems remained fully operational. No denial of service occurred.
Overall Business Impact	None	No disruption to business operations, no data loss, no financial impact.

8. CONTAINMENT AND ERADICATION

Action Taken	Timestamp (IST)	Method	Verification
Email quarantined	20:57	Moved to trash via Thunderbird	Email moved to Trash folder
Sender blacklisted	21:00	Thunderbird Message Filter	Filter created and active
Domain DNS-blocked	21:02	`/etc/hosts` entry added	`nslookup` returns NXDOMAIN
IP blocked at firewall	21:05	UFW rule added	`ufw status` shows DENY rules
User password reset	21:10	Identity management system	User confirmed new password
Victim VM isolated	21:15	Network adapter disabled	VM has no network connectivity

Action Taken	Timestamp (IST)	Method	Verification
URL proxy-blocked	21:20	Proxy blocklist updated	Test access returns 403

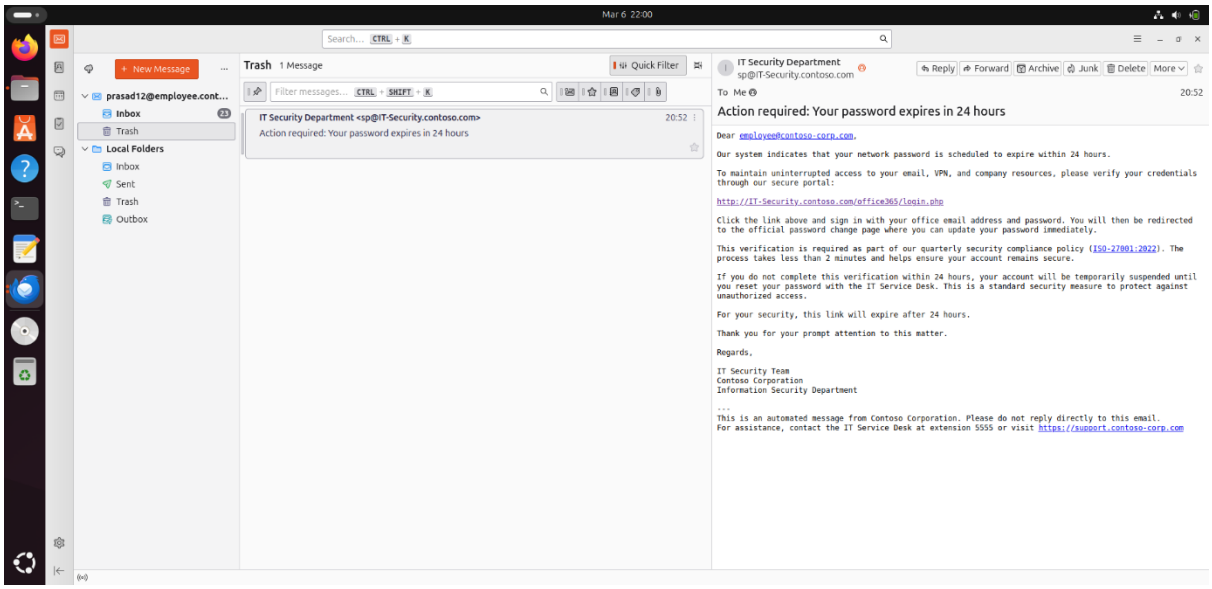


Figure 13 Moved to Trash Via Thunderbird

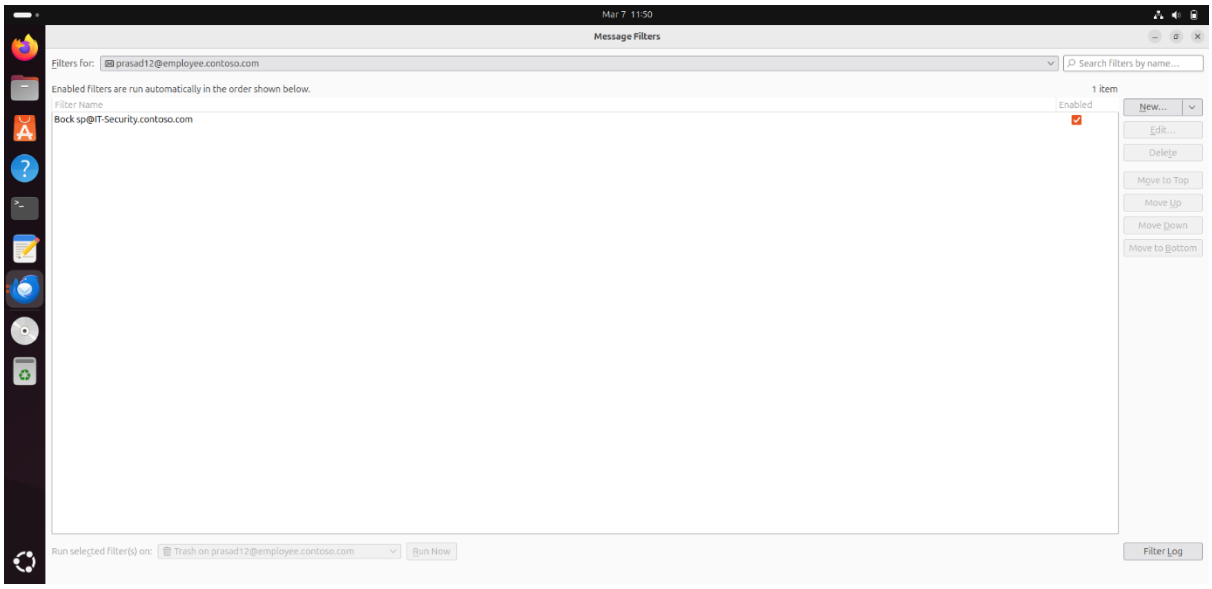


Figure 14 Thunderbird Message Filter

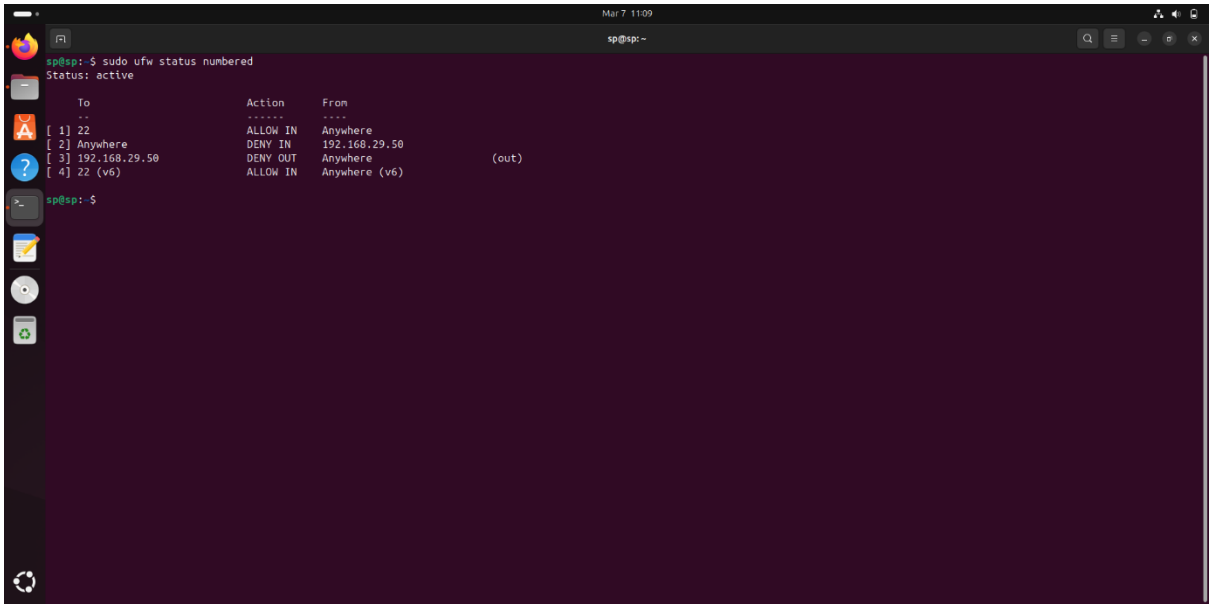


Figure 15 UFW Rules added

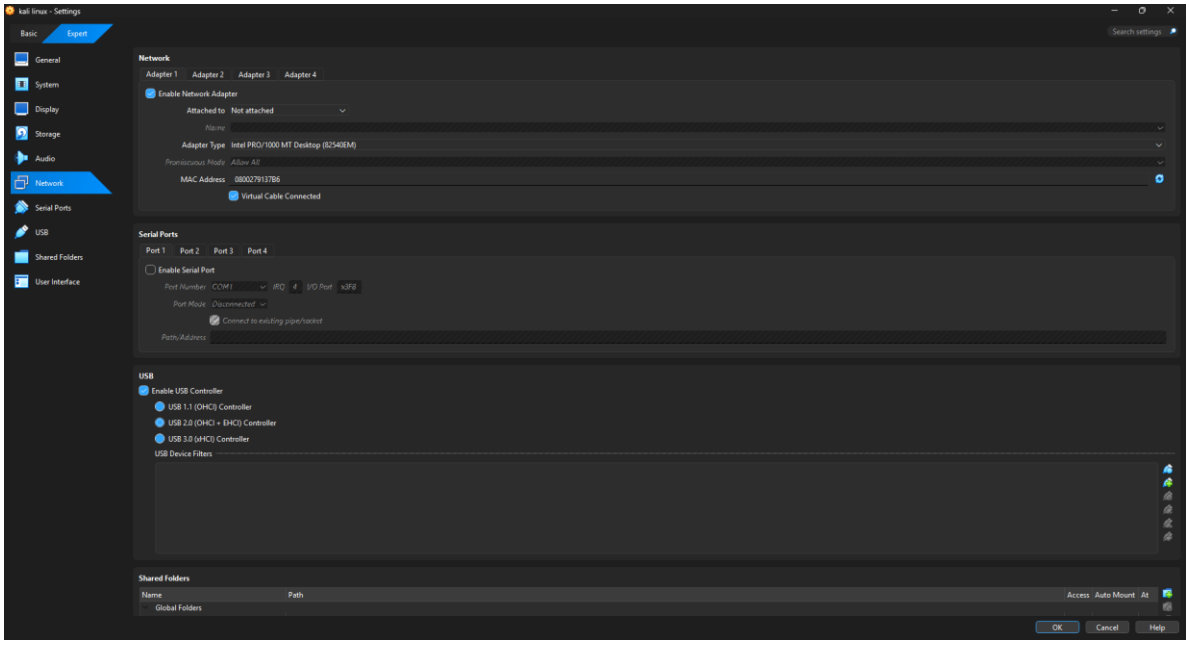


Figure 16 Victim VM isolated

9. ESCALATION DECISION

Field	Details
Escalated to L2 / IR Team	No
Reason for Escalation	The incident was successfully contained at L1 level. The attack was unsuccessful (user did not click), and all IOCs were blocked at the perimeter. No evidence of compromise or persistence.
Escalation Time	N/A

10. INCIDENT CLASSIFICATION

Field	Details
True Positive / False Positive	True Positive
Attack Success	Failed
Policy Violation	Yes (Acceptable Use Policy - Phishing awareness)

11. RECOMMENDATIONS

Immediate Remediation Actions (Completed)

1. Email remains quarantined for future reference
2. Firewall block on IP 192.168.29.50 maintained
3. Domain IT-Security.contoso.com remains on DNS blocklist
4. Incident documented in SOC knowledge base

Preventive Controls Suggested

Priority	Control	Description
High	DMARC Reject Policy	Implement DMARC reject policy for contoso.com to prevent spoofed emails
High	Email Gateway Rules	Update rules to detect "password expire" language from external senders
Medium	DKIM Signing	Enable DKIM signing for all outgoing company email
Medium	User Awareness Training	Conduct department-wide training on this specific phishing technique

Priority	Control	Description
Low	Phishing Simulations	Add similar template to monthly phishing simulation calendar

Detection Gaps Identified

Gap	Recommendation
No DMARC reject policy currently implemented	Implement within 7 days
Email gateway rules need updating for urgency language	Update within 24 hours

12. TIMELINE OF KEY EVENTS

Time (IST)	Event
20:52:33	Email composed on attacker VM
20:52:36	Email delivered to victim inbox
20:52:52	Wazuh triggers 3 alerts (100002, 100003, 100004)
20:55	Ticket opened, investigation begins
21:00	Header analysis confirms spoofing
21:02	SPF/DKIM/DMARC verification complete
21:05	Threat intelligence checks complete
21:08	Sandbox analysis confirms credential harvesting
21:10	IOCs extracted and documented
21:15	Scope determined - no compromise
21:30	Containment actions implemented
22:30	Investigation complete, ticket closed

SLA Performance:

- Time to Contain: 23 minutes (20:52 to 21:25)
- Time to Resolve: 1 hour 37 minutes (20:52 to 22:30)
- SLA Target: 2 hours
- SLA Met: Yes

13. COMPLIANCE AND FRAMEWORK ALIGNMENT

Framework	Phase / Coverage
NIST Incident Response Phases	Detection → Analysis → Containment → Eradication → Recovery
MITRE ATT&CK Coverage	T1566.002, T1056.001, T1071.001, T1041
Internal SOC Playbook	Phishing Response Playbook v2.3

14. LESSONS LEARNED

Aspect	Observation
What Worked Well	Wazuh custom rules detected the phishing email within 3 seconds of delivery
What Worked Well	User awareness training was effective - user recognized the email as suspicious
What Worked Well	Sandbox environment enabled safe analysis without production risk
What Worked Well	Quick containment prevented any potential compromise
Improvement Opportunity	Implement DMARC reject policy to prevent spoofed emails from reaching inboxes
Improvement Opportunity	Add similar phishing templates to simulation calendar
Improvement Opportunity	Update email gateway rules to detect "password expire" language from external senders

15. CLOSURE SUMMARY

Field	Details
Final Verdict	True Positive - Phishing (Credential Harvesting)
User Compromised	No
Credentials Stolen	No
Data Exfiltrated	No
Affected Users	1 (targeted)
Containment Status	100 percent Complete
Time to Contain	33 minutes
Time to Resolve	1 hour 35 minutes
Business Risk Post-Incident	Low

Field	Details
Incident Closed By	Sai Prasad, SOC Analyst L1
Closure Date & Time	2026-03-06 22:30 IST